

Vulnerability Assessment Report

Publicly Accessible Database Server — E-Commerce Company Prepared

by: G S Krishna Chandra | Framework: NIST SP 800-30 Rev. 1 | Google Cybersecurity Certificate —
Course 5 Assets, Threats, and Vulnerabilities | Date: 7th March, 2026.

System Description

The server hardware consists of a powerful CPU processor and 128GB of memory. It runs on the latest version of the Linux operating system and hosts a MySQL database management system. It is configured with a stable network connection using IPv4 addresses and interacts with other servers on the network. Security measures include SSL/TLS encrypted connections.

Scope

The scope of this vulnerability assessment relates to the current access controls of the system. The assessment covers a period of three months, from June 20XX to August 20XX. NIST SP 800-30 Rev. 1 is used to guide the risk analysis of the information system. This assessment focuses on the confidentiality, integrity, and availability of the data on the server, and does not cover the physical security of the server or related IT infrastructure.

Purpose

The purpose of this vulnerability assessment is to evaluate the security risks associated with the company's publicly accessible database server. This server is critical to business operations, as employees worldwide rely on it to query customer data and identify potential leads. Securing this data is essential to protect customer privacy, maintain regulatory compliance, and preserve business reputation. If the server were compromised or disabled, the company could face data breaches, financial losses, and a complete halt to remote sales operations until the issue is resolved.

Risk Assessment

Threat Source	Threat Event	Likelihood	Severity	Risk
Hacker (Outsider)	Obtain sensitive information via exfiltration	3	3	9
Hactivist (Outsider)	Conduct Denial of Service (DoS) attacks	3	2	6
Competitor (Group)	Perform reconnaissance and surveillance of organization	2	2	4

Risk = Likelihood (1–3) × Severity (1–3). Scores of 6–9 indicate high risk, 3–4 indicate moderate risk, and 1–2 indicate low risk.

Approach

This was a qualitative vulnerability assessment, relying on subjective judgment informed by NIST SP 800-30 Rev. 1 to estimate likelihood and severity. I selected these three threat source/event pairs because they directly

relate to the server's primary vulnerability — being publicly accessible without restricted access controls.

Exfiltration of sensitive customer data and DoS attacks were rated highest, as a public-facing database with no access restrictions makes both highly likely and severely impactful. Reconnaissance was rated moderate, as it typically precedes a more damaging attack. A limitation of this assessment is that scores are based on general security knowledge rather than direct system testing or logged data.

Remediation Strategy

Currently, SSL/TLS encryption is the only meaningful control protecting data in transit, but the database itself remains open to the public with no access restrictions. To remediate the highest risks, the company should implement the principle of least privilege, ensuring only authorized employees and systems can query the database. Multi-factor authentication (MFA) should be required for all access to reduce the risk of credential-based exfiltration. An Authentication, Authorization, and Accounting (AAA) framework should be adopted to log and monitor all access attempts, helping detect reconnaissance activity early. Finally, adopting a defense-in-depth approach — combining firewalls, intrusion detection systems, and network segmentation — would reduce the impact of a DoS attack and limit an attacker's ability to reach the database directly, significantly improving the server's overall security posture.